

MAPEO DETALLADO: MÉTRICAS → REQUISITOS NORMATIVOS DORA

Matriz Trazabilidad Indicadores a Artículos DORA

Versión: 1.0

Fecha: Enero 2026

Clasificación: Profesional — Marco de Cumplimiento Normativo

Aplicabilidad: España, Instituciones Financieras, Regulación DORA (EU 2022/2554)

INTRODUCCIÓN

Esta matriz mapea **15 indicadores DORA** clave directamente a:

1. **Artículos específicos del Reglamento DORA (EU 2022/2554)**
2. **Normas Técnicas Regulatorias (RTS) de ESAs (EBA, ESMA, EIOPA)**
3. **Requisitos técnicos detallados**
4. **Evidencia de cumplimiento requerida**

Uso: Justificación regulatoria de inversiones técnicas; preparación para auditoría supervisora.

MATRIZ COMPLETA: INDICADORES → DORA ARTICLES → RTS → EVIDENCIA

INDICADOR 1: MTTD <15 Minutos

Campo	Descripción
Indicador	Mean Time To Detect (MTTD) < 15 minutos
Artículo DORA	Art. 18 (Detección de incidentes TIC)
Texto Artículo	"Los proveedores de servicios de entidades han de detectar los incidentes TIC graves con la máxima rapidez"
RTS Aplicable	EBA/ESMA/EIOPA RTS on Major ICT-Related Incidents (Part 4, Classification)
Requisito Técnico	Tiempo promedio desde ocurrencia de evento TIC hasta generación de alerta escalada ≤15 minutos
Componentes Medición	- Timestamp eventos (SIEM source) - Timestamp detección (SIEM alert generated) - Sincronización horaria NTP ±100ms
Frecuencia Reporte	Diaria; agregación semanal; escalation si >20min
Herramientas Requeridas	SIEM (Splunk, ELK, Sumo Logic); alerting rules; escalation workflows
Evidencia Cumplimiento	- SIEM dashboard mostrando MTTD trending - Logs de sincronización NTP - Documentación de alert rules DORA-aligned - Reportes mensuales CRO
Benchmark Regulatorio	Banco de España: <30 min (aconsejable) DORA target: <15 min (recomendable para significativas)
Supervisory Focus	¿Detecta 95%+ incidentes críticos? ¿Dentro 15 min? ¿Escala alerts correctamente?

INDICADOR 2: MTTR <4 Horas (Críticos)

Campo	Descripción
Indicador	Mean Time To Remediate (MTTR) <4 horas para incidentes críticos
Artículo DORA	Art. 20 (Respuesta a incidentes); Art. 19 (Notificación autoridades)
Texto Artículo	"Reparación rápida e información periódica a supervisores de incidentes graves"
RTS Aplicable	EBA RTS on Incident Reporting Timelines; EBA Guidelines Incident Response
Requisito Técnico	Tiempo desde confirmación de incidente hasta restauración servicio ≤4h (críticos); ≤8h (importantes)
Componentes Medición	- Timestamp confirmación incidente - Timestamp de restauración completada - Verificación independiente de restauración
Frecuencia Reporte	Real-time alerts si >3h; escalation inmediata CRO
Herramientas Requeridas	Incident Management System (Jira, ServiceNow); runbooks automatizados; monitoring restauración
Evidencia Cumplimiento	- Incident tickets con timelines documentadas - SLA breach logs - Restoration verification reports - Board reporting MTTR trends
Benchmark Regulatorio	DORA: <4h objetivo; Banco de España auditoría verifica cumplimiento
Supervisory Focus	¿Restoration timelines cumplen SLA? ¿Hay runbooks para tipos incidente principales?

INDICADOR 3: Patch Rate (CVSS ≥ 7.0 parchadas ≤ 30 días)

Campo	Descripción
Indicador	% Vulnerabilidades CVSS ≥ 7.0 parchadas dentro 30 días
Artículo DORA	Art. 24 (Evaluación de vulnerabilidades periódicas)
Texto Artículo	"Las entidades llevarán a cabo evaluaciones periódicas de vulnerabilidades...de sus sistemas de información"
RTS Aplicable	EBA RTS Art. 6 (ICT Risk Mgmt Framework); Vulnerability Management procedures
Requisito Técnico	Scanning semanal de vulnerabilidades; identificación CVSS; remediación $< 30d$ para críticas
Componentes Medición	- Vulnerabilities database (Nessus, Qualys, Rapid7) - CVSS scoring automático - Patch deployment tracking - Re-scanning post-patch
Frecuencia Reporte	Semanal; dashboard real-time; reporte mensual a CISO
Herramientas Requeridas	Vulnerability Scanner; Patch Management platform (e.g., Rapid7 Insightvm); CMDB
Evidencia Cumplimiento	- Scanning results (timestamps) - Patch deployment logs - Re-scan confirmación remediación - Trending reports 90 días
Benchmark Regulatorio	DORA: 100% CVSS ≥ 7 parchadas $\leq 30d$ CIS Controls: Priority 1
Supervisory Focus	¿Cobertura scanning 100% sistemas críticos? ¿Exceptions documentadas? ¿Patching delays?

INDICADOR 4: False Positive Rate (% Alertas Falsas)

Campo	Descripción
Indicador	% Alertas no-verdaderas (False Positive Rate)
Artículo DORA	Art. 18 (implícito en "detección de incidentes"); Art. 10 (Monitoring continuo)
Texto Artículo	"Detección...incidentes graves requiere processes eficientes"
RTS Aplicable	EBA Guidelines on IT Controls; SIEM effectiveness metrics
Requisito Técnico	FPR <10% (industria best practice); <5% objetivo avanzado
Componentes Medición	- SIEM alert logs - Manual analyst validation - Classification true positive vs false positive
Frecuencia Reporte	Mensual; trending analysis; SLA if >10%
Herramientas Requeridas	SIEM tuning/optimization; Analyst feedback loops; ML-based anomaly detection
Evidencia Cumplimiento	- SIEM tuning documentation - FPR calculation methodology - Monthly FPR trend reports - Rule effectiveness analysis
Benchmark Regulatorio	NIST CSF: Reduce false positives via tuning ENISA: <10% acceptable
Supervisory Focus	¿FPR impacta SOC efficiency? ¿Tuning frequency? ¿Analyst burnout?

INDICADOR 5: Vulnerability Assessment Coverage (%)

Campo	Descripción
Indicador	% Sistemas/Assets escaneados por vulnerabilidades
Artículo DORA	Art. 24 (Evaluaciones periódicas vulnerabilidades)
Texto Artículo	"...evaluaciones periódicas de vulnerabilidades de sus sistemas"
RTS Aplicable	EBA RTS Art. 6 (Vulnerability Management framework); NIST SP 800-30 (Rev. 1)
Requisito Técnico	Cobertura 100% sistemas críticos; 95% sistemas importantes; ≥85% total
Componentes Medición	- Asset inventory (CMDB) - Scanning results - Coverage calculation (escaneados/total)
Frecuencia Reporte	Semanal; gap analysis mensual
Herramientas Requeridas	Vulnerability Scanner; CMDB integration; Asset management tools
Evidencia Cumplimiento	- Asset inventory reports - Scanning exclusions documented - Gap closure plans - Coverage trending
Benchmark Regulatorio	DORA: 100% críticos EU supervisors: Verifican cobertura exhaustividad
Supervisory Focus	¿Qué sistemas NO se escanean? ¿Por qué? ¿Plan para incluirlos?

INDICADOR 6: Third-Party Risk Assessment Coverage (%)

Campo	Descripción
Indicador	% Proveedores críticos con evaluación formal due diligence
Artículo DORA	Art. 28 (Due diligence precontractual)
Texto Artículo	"Llevarán a cabo un procedimiento de due diligence...en relación con los posibles riesgos"
RTS Aplicable	EBA RTS Art. 28-30 (Outsourcing; Third-party risk); ESMA RTS third-party mgmt
Requisito Técnico	Due diligence evaluation para 100% proveedores críticos; scoring framework documentado
Componentes Medición	- Vendor inventory - Evaluation questionnaire responses - Risk scoring - Coverage %
Frecuencia Reporte	Trimestral; re-evaluation anual
Herramientas Requeridas	TPRM platform (e.g., OneTrust, ServiceNow); vendor questionnaire; scoring engine
Evidencia Cumplimiento	- Vendor inventory report - Due diligence questionnaire responses - Risk scores - Evaluation dates - Closure of findings
Benchmark Regulatorio	DORA: 100% críticos evaluados CNMV España: Auditoría específica terceros
Supervisory Focus	¿Quién se considera "crítico"? ¿Evaluación rigor? ¿Subcontratos incluidos?

INDICADOR 7: DORA-Compliant Contracts (%)

Campo	Descripción
Indicador	% Contratos proveedores con cláusulas DORA-compliant
Artículo DORA	Art. 30 (Requisitos contractuales)
Texto Artículo	"Los contratos...contendrán disposiciones...incluida la seguridad de la información...y el acceso a datos"
RTS Aplicable	EBA RTS Part 6 (Contractual requirements); ESMA RTS 2022/991 Art. 18-22
Requisito Técnico	Contratos con cláusulas: - Incident notification (24h/72h) - Audit rights (anual) - SLA (RTO/RPO) - Sub-contractor clause - Termination/exit provisions - Data handling/encryption - Breach notification
Componentes Medición	- Contract repository - DORA checklist validation - % compliant contracts - Remediation tracking
Frecuencia Reporte	Trimestral; tracking of renegotiations
Herramientas Requeridas	Contract management platform; DORA checklist; legal workflow tools
Evidencia Cumplimiento	- Executed contracts (2+ años recent) - DORA clause mapping - Renegotiation log - Exceptions documented
Benchmark Regulatorio	DORA: 100% compliance objetivo CNMV: Verifica cláusulas audit
Supervisory Focus	¿Todos contratos DORA-compliant? ¿Grandfathered contracts? ¿Timeline renegociación?

INDICADOR 8: Threat-Led Penetration Testing (TLPT) Completion

Campo	Descripción
Indicador	Realización TLPT bienal (cada 3 años máximo)
Artículo DORA	Art. 26 (Testing de resiliencia operativa)
Texto Artículo	"Los proveedores de servicios financieros...realizarán pruebas avanzadas...pruebas de penetración dirigidas por amenazas"
RTS Aplicable	EBA RTS Part 7 (Testing requirements); TIBER-EU methodology (central bank framework)
Requisito Técnico	TLPT bienal mínimo para entidades significativas; metodología TIBER-EU; cobertura ≥80% sistemas críticos
Componentes Medición	- TLPT charter aprobada - Red team qualification verified - Testing scope documented - Findings count/severity - Remediation tracking
Frecuencia Reporte	Post-TLPT (90 días); remediation status trimestral
Herramientas Requeridas	Certified red team (TIBER-EU accredited); penetration testing platform; findings tracker
Evidencia Cumplimiento	- TLPT charter signed - Red team credentials - Testing report (findings) - Remediation plan - Board approval - Supervisory submission
Benchmark Regulatorio	DORA: Obligatorio significativas; recomendado importantes EBA: Bienal cadence verificado auditoría
Supervisory Focus	¿TLPT realizado? ¿Metodología TIBER-EU? ¿Cobertura sistemas críticos? ¿Remediation status?

INDICADOR 9: Incident Notification Compliance (<4h)

Campo	Descripción
Indicador	% Incidentes mayores llevados notificados a supervisores ≤ 4 horas
Artículo DORA	Art. 19 (Notificación de incidentes graves)
Texto Artículo	"Las entidades notificarán...a la autoridad competente...en los 4 horas de determinar que...se trata de un incidente grave"
RTS Aplicable	EBA/ESMA/EIOPA RTS on Major ICT-Related Incidents (Reporting timelines Part 3)
Requisito Técnico	4h initial notification; 72h intermediate; 30d final report; supervisory acknowledgment required
Componentes Medición	- Incident detection timestamp - Classification timestamp - Supervisory submission timestamp - Acknowledgment receipt timestamp
Frecuencia Reporte	Real-time; alerts at 3h mark
Herramientas Requeridas	Incident management system; notification automation; supervisory portal (CNMV/Banco España)
Evidencia Cumplimiento	- Incident ticket timeline - Supervisory submission email/portal log - Acknowledgment receipt - Compliance report (% on-time)
Benchmark Regulatorio	DORA: 4h non-negotiable CNMV: Verificación auditoría 100% compliance histórico
Supervisory Focus	¿Notificaciones dentro 4h? ¿Ninguna demora? ¿Proceso automatizado?

INDICADOR 10: Phishing Click Rate (%)

Campo	Descripción
Indicador	% Empleados que hacen click en emails phishing simulados
Artículo DORA	Art. 14 (Implícito en awareness/training requirements)
Texto Artículo	"Sensibilización...personal...ciberseguridad"
RTS Aplicable	EBA Guidelines on IT Governance; NIST CSF Awareness & Training
Requisito Técnico	Monthly phishing simulations; click rate tracking; training trigger >8%
Componentes Medición	- Phishing simulation platform - Click tracking - User identification - Training assignment - Retesting
Frecuencia Reporte	Mensual; departmental breakdown
Herramientas Requeridas	Phishing simulation platform (KnowBe4, Gophish); LMS integration; reporting
Evidencia Cumplimiento	- Simulation campaign records - Click data per user - Training assignment logs - Retest results - Trending improvements
Benchmark Regulatorio	Industry: <8% acceptable; <5% good Objetivo DORA: Cultura seguridad fuerte
Supervisory Focus	¿Click rates trending down? ¿Training tied to incidents? ¿Repeated offenders addressed?

INDICADOR 11: Board Training Completion (%)

Campo	Descripción
Indicador	% Miembros Junta Directiva que completaron training DORA
Artículo DORA	Art. 5 (Governance); Art. 14 (Awareness)
Texto Artículo	"Los órganos directivos...poseen...conocimientos suficientes" de ciberseguridad
RTS Aplicable	EBA Guidelines on Governance; European Corporate Governance codes
Requisito Técnico	100% board members trained; annual refresher; documented assessment
Componentes Medición	- Training attendance - Assessment scores - Completion date - Renewal date
Frecuencia Reporte	Annual; pre-audit verification
Herramientas Requeridas	LMS; training modules; assessment exams
Evidencia Cumplimiento	- Training attendance list - Assessment scores - Training certificates - Audit trail LMS
Benchmark Regulatorio	DORA: 100% compliance Supervisors: Verifican anualmente
Supervisory Focus	¿100% board trained? ¿Anualmente? ¿Assessment results?

INDICADOR 12: Business Continuity Testing (% Completado)

Campo	Descripción
Indicador	% Planes continuidad negocio testeados (anual/semestral)
Artículo DORA	Art. 25 (Testing de resiliencia operativa); Art. 2 (Funciones críticas)
Texto Artículo	"Pruebas...verificarán...capacidad de continuar...servicios...en caso de perturbación grave"
RTS Aplicable	EBA RTS Part 7 (Testing types); EBA Guidelines on Stress Testing
Requisito Técnico	Annual tabletop minimum; semi-annual full exercise; site activation testing
Componentes Medición	- Test schedule - Participant list - Scenario documentation - Results/gaps - Remediation tracking
Frecuencia Reporte	Post-test (30 days); annual summary
Herramientas Requeridas	Test scheduling tool; scenario playbooks; incident simulation platform
Evidencia Cumplimiento	- Test plans/charters - Participant logs - Exercise results - Findings/actions - Board reporting
Benchmark Regulatorio	DORA: Annual mínimo Supervisors: Verifica cadencia/realismo
Supervisory Focus	¿Testing anual realizado? ¿Realismo de escenarios? ¿RTO/RPO validation?

INDICADOR 13: ICT Risk Framework Evaluation (%)

Campo	Descripción
Indicador	% Cobertura de framework de gestión riesgos TIC conforme DORA
Artículo DORA	Art. 6 (ICT Risk Management Framework)
Texto Artículo	"Marco integral de gestión de riesgos TIC...basado en la evaluación de riesgos"
RTS Aplicable	EBA RTS Art. 6; NIST CSF 2.0; ISO 27001 Annex A controls
Requisito Técnico	Framework cubre: policies, controls, governance, monitoring, incident response, BC/DR, training
Componentes Medición	- Policy documentation - Control inventory - Gap assessment - Closure tracking - Coverage %
Frecuencia Reporte	Anual; auditoría externa verificación
Herramientas Requeridas	GRC platform (OneTrust, Archer); policy management; control testing
Evidencia Cumplimiento	- Policy documents - Control matrix - Gap analysis - External audit report - Remediation status
Benchmark Regulatorio	DORA: 100% framework coverage objetivo Supervisors: Audit GAP versus DORA/NIST
Supervisory Focus	¿Framework documentado? ¿Completo vs DORA? ¿Gaps known/addressed?

INDICADOR 14: Cryptography Implementation (%)

Campo	Descripción
Indicador	% Assets con encriptación datos en tránsito y reposo
Artículo DORA	Art. 9 (Gestión de acceso y criptografía)
Texto Artículo	"Usar mecanismos criptográficos robustos...para proteger la información sensible"
RTS Aplicable	EBA RTS Art. 9; NIST SP 800-175B (Cryptographic Key Management)
Requisito Técnico	TLS 1.3+ para tránsito; AES-256+ para reposo; key management formalizado
Componentes Medición	- Encryption scanning - Algorithm validation - Key management audit - Coverage % (encrypted/total)
Frecuencia Reporte	Trimestral; anual compliance audit
Herramientas Requeridas	Encryption scanning tools; HSM (Hardware Security Module); key management system
Evidencia Cumplimiento	- Encryption inventory - Algorithm documentation - Key rotation logs - Encryption scanning results
Benchmark Regulatorio	DORA: 100% sensitive data encrypted objetivo PCI DSS: Compliance requirement
Supervisory Focus	¿Cobertura datos sensibles? ¿Algoritmos actuales? ¿Key management formal?

INDICADOR 15: Incident Response SLA Achievement (%)

Campo	Descripción
Indicador	% Incidentes remediados dentro SLA (by severity tier)
Artículo DORA	Art. 20 (Incident response)
Texto Artículo	"Respuesta rápida...reparación pronta de incidentes graves"
RTS Aplicable	EBA Guidelines on Incident Response; NIST SP 800-61 (Computer Security Incident Handling)
Requisito Técnico	Critical: <4h; High: <8h; Medium: <24h; Low: <5 días
Componentes Medición	- Incident severity classification - SLA definition - Closure timestamp - SLA achievement %
Frecuencia Reporte	Semanal; monthly to management
Herramientas Requeridas	Incident management system (Jira, ServiceNow) with SLA tracking
Evidencia Cumplimiento	- SLA policy document - Incident tickets with SLA fields - SLA compliance reports - Breaches log
Benchmark Regulatorio	DORA: SLA compliance objetivo >95% Industria: Typical 85-95%
Supervisory Focus	¿SLA definidos? ¿Compliance rate? ¿Breaches análisis?

RESUMEN: TRAZABILIDAD POR ARTÍCULO DORA

ART. 5 (Governance)

- Board Training Completion (Indicator 11)
- Incident Notification Compliance (Indicator 9)

ART. 6 (ICT Risk Framework)

- ICT Risk Framework Evaluation (Indicator 13)
- Vulnerability Coverage (Indicator 5)

ART. 9 (Encryption)

- Cryptography Implementation (Indicator 14)

ART. 14 (Awareness)

- Phishing Click Rate (Indicator 10)
- Board Training (Indicator 11)

ART. 18 (Detection)

- MTTD <15 min (Indicator 1)
- False Positive Rate (Indicator 4)

ART. 19-20 (Notification + Response)

- Incident Notification <4h (Indicator 9)
- MTTR <4h (Indicator 2)
- Incident Response SLA (Indicator 15)

ART. 24 (Testing - Vulnerability Assessment)

- Patch Rate (Indicator 3)
- Vulnerability Coverage (Indicator 5)

ART. 25 (Testing - Resilience)

- Business Continuity Testing (Indicator 12)

ART. 26 (Testing - TLPT)

- TLPT Completion (Indicator 8)

ART. 28-30 (Third-Party Risk)

- Third-Party Assessment Coverage (Indicator 6)
- DORA-Compliant Contracts (Indicator 7)

USO PRÁCTICO: AUDITORÍA SUPERVISORA

Preparación para auditoría supervisora:

1. ✓ Recopilar evidencia por Art. DORA (usar matriz arriba)
2. ✓ Verificar score PRAGMATIC de cada métrica
3. ✓ Documentar frecuencia de reporte
4. ✓ Preparar trending data (12 meses mínimo)
5. ✓ Demostrar governance/ownership de cada indicador

Red flags para supervisores:

- ⚠ MTTD > 20 minutos
- ⚠ Patch rate < 90%
- ⚠ Vendor coverage < 95%

⚠ TLPT no realizado (para significativas)

⚠ Incident notification delays

Fin del Mapeo

Enero 2026 — Matriz Trazabilidad Integral para Cumplimiento DORA